SPLUNK ET MISE ŒUVRE

A. EXPLICATION

C’est quoi Splunk

Splunk est un **SIEM** qui permet de collecter, analyser et visualiser des logs en temps réel.

Il centralise des données provenant de différentes sources (fichiers logs, syslogs, journaux Windows, bases de données) afin de surveiller les systèmes, détecter des anomalies et faciliter l’investigation.

Son fonctionnement repose sur :

- Des **forwarders** qui collectent les logs
- Un **indexeur** qui stocke et organise les données
- Une interface web permettant la recherche, l’analyse et la visualisation

Splunk offre également des tableaux de bord et des alertes pour suivre les événements et détecter les activités suspectes.

Processus de mise en œuvre de Splunk

La mise en place de Splunk se déroule en plusieurs étapes :

- **Préparation** : identifier les sources de logs et définir les besoins en stockage et performance
- **Installation** : déployer les composants (forwarders, indexers, search heads)
- **Configuration** : configurer la collecte et l’envoi des logs vers l’indexeur
- **Ajout de données** : intégrer les différentes sources (logs, bases de données, APIs, etc.)
- **Analyse & visualisation** : exploiter les données via recherches, dashboards et alertes
- **Optimisation** : améliorer les performances (gestion des données, architecture)
- **Maintenance** : assurer la mise à jour, la sauvegarde et la résolution des incident
- **Surveillance & sécurité** : s’assurer que l’environnement Splunk est protégé en surveillant en continu les activités et en appliquant des bonnes pratiques de sécurité.

B. PRATIQUE

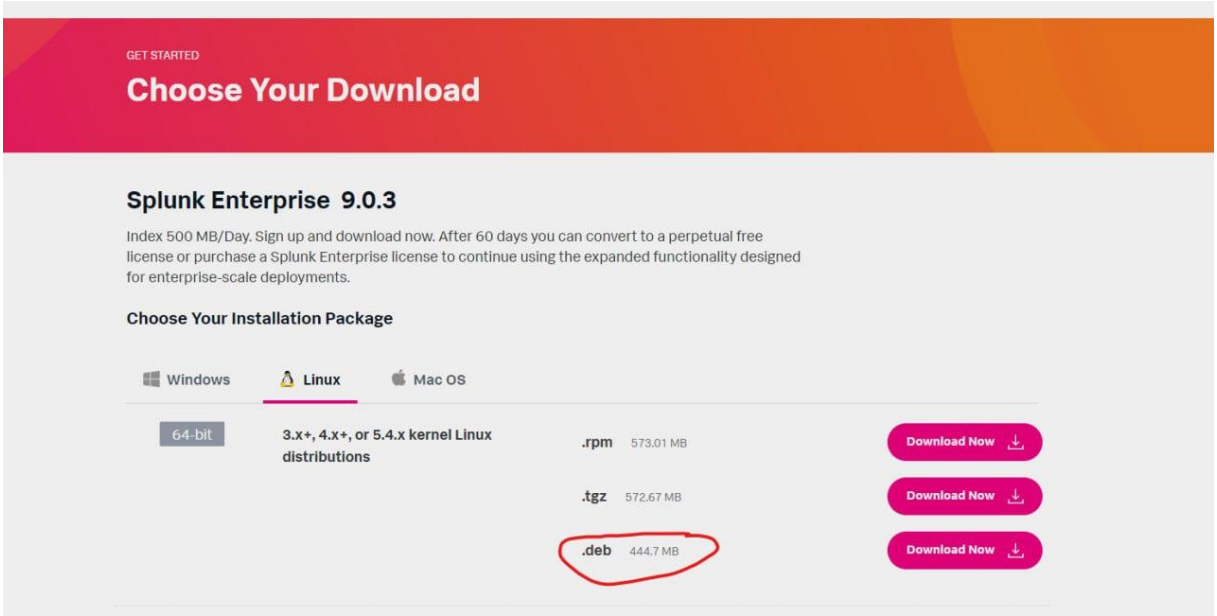
Passage à la pratique

Pour mettre en œuvre Splunk, nous utilisons un environnement virtualisé afin de simuler son fonctionnement.

Le lab se compose de :

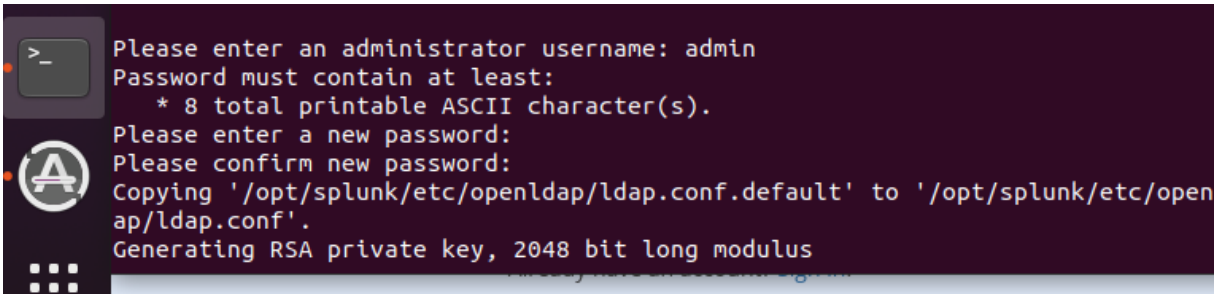
- Une machine **Windows** (cible à surveiller)
- Un serveur **Ubuntu** (hébergeant Splunk)

Nous commençons par télécharger la version adaptée à notre système depuis le site officiel de Splunk. Dans notre cas, nous utilisons la version Linux sur Ubuntu, disponible en essai gratuit de 60 jours.



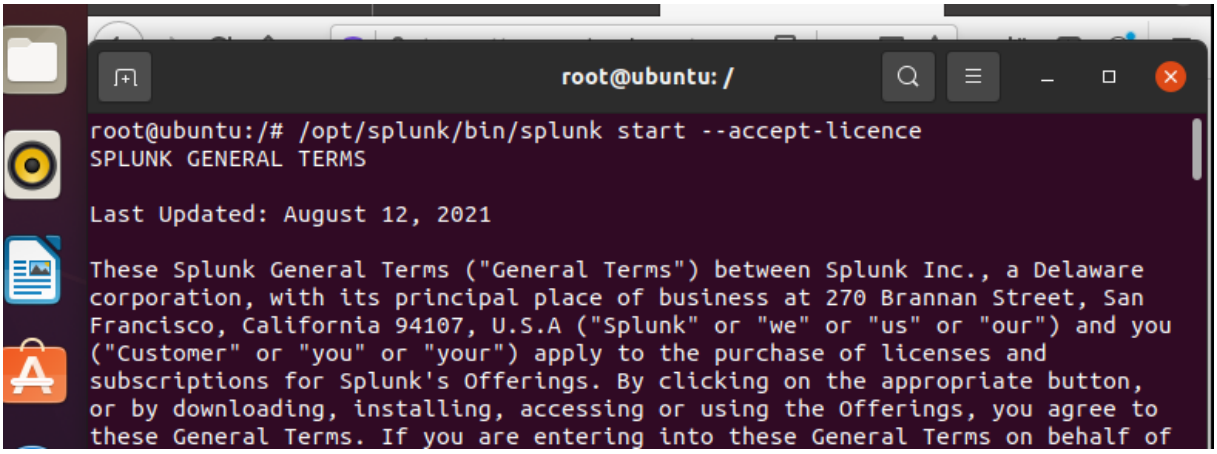
Après le téléchargement du fichier, on ouvre un terminal et on installe le paquet à l'aide de la commande **dpkg**.

Pendant l'installation, il est demandé de créer un mot de passe administrateur, comme illustré sur l'image suivante.



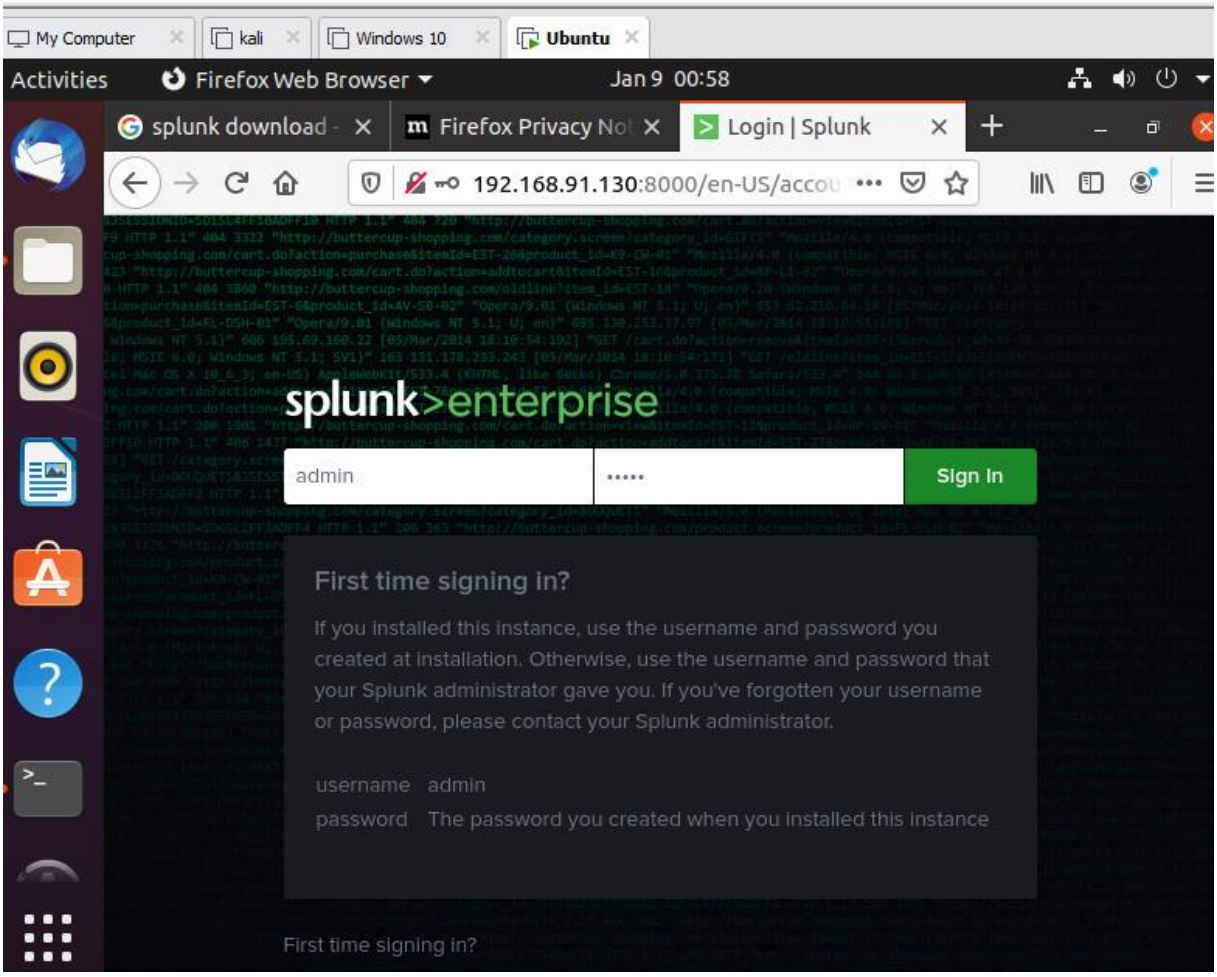
Ensuite, nous acceptons la licence. Pour cela, on se rend dans le répertoire **/opt/splunk/bin**, puis on lance la commande suivante :

splunk start –accept-licence comme illustré sur l'image ci-dessous.



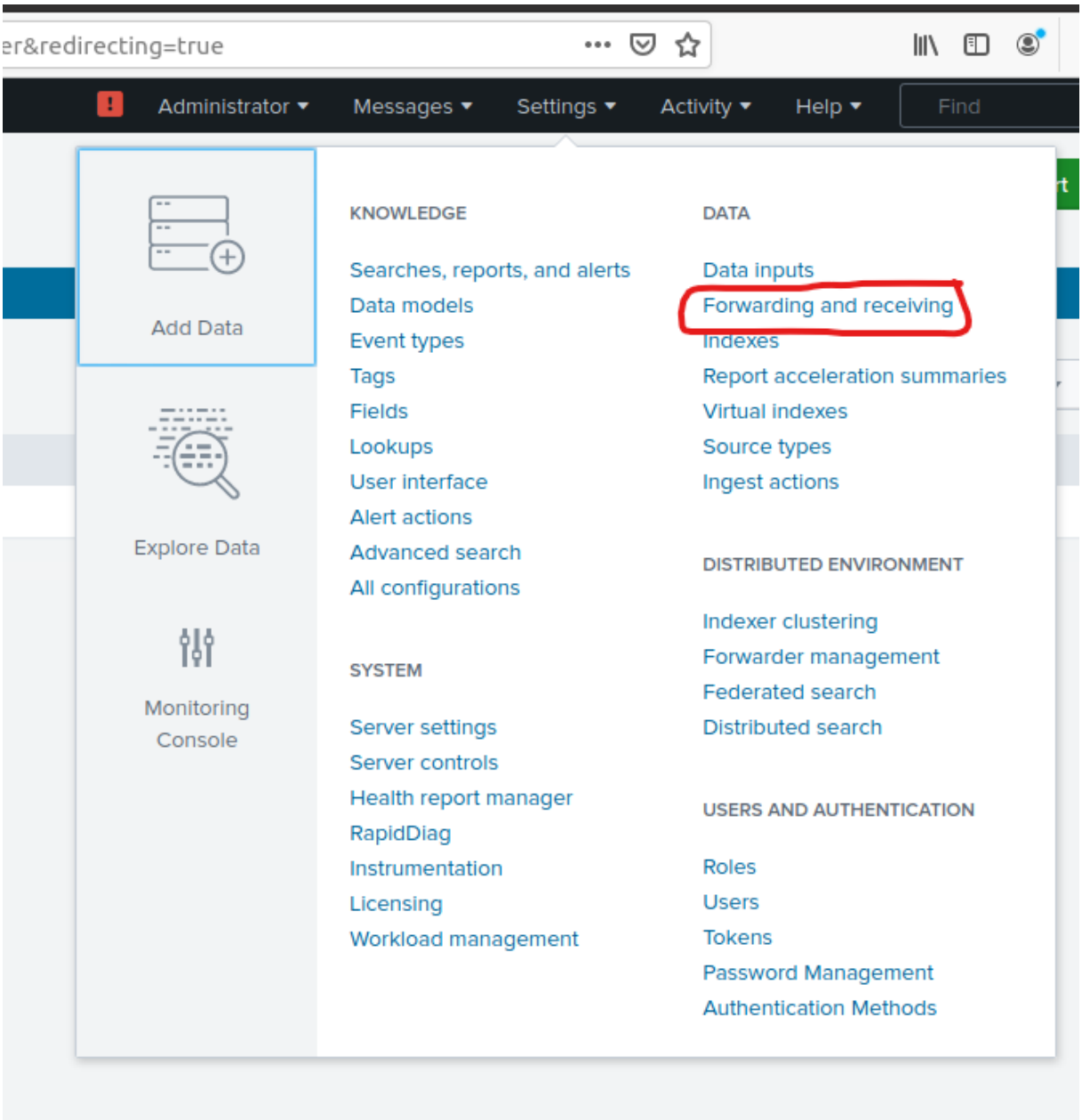
Une fois l'installation terminée, on ouvre un navigateur et on accède à l'interface web de Splunk via l'URL suivante : http://localhost:8000

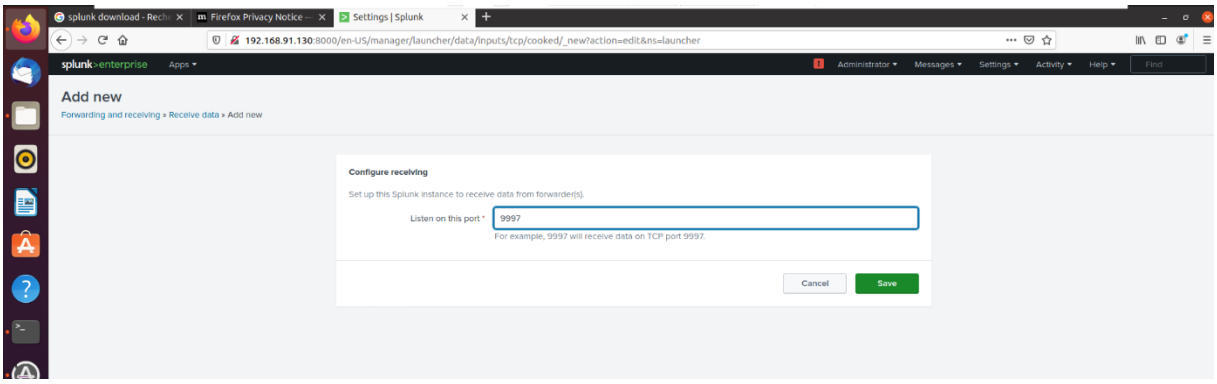
Il est également possible d'y accéder en utilisant l'adresse IP de la machine, comme illustré sur l'image suivante.



Ajoutons maintenant des données à Splunk en configurant différentes sources, comme les fichiers de logs, les bases de données, les réseaux ou encore les APIs. Pour cela, nous commençons par créer un port de réception. On se rend dans **Settings → Forwarding and Receiving**, puis dans la section **Data**.

Sur la page qui s'affiche, on crée un nouveau port de réception (par défaut **9997**) et on enregistre.

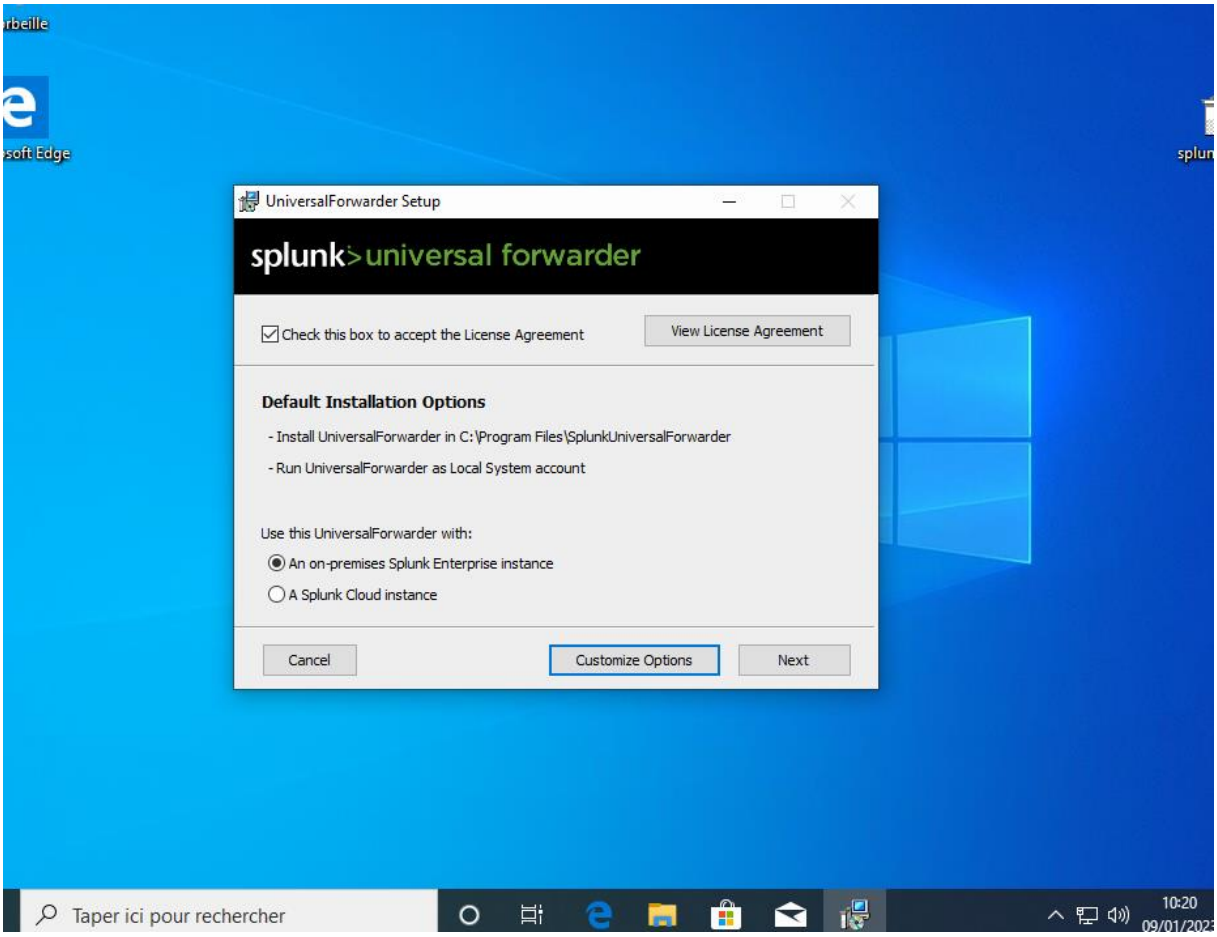

er&redirecting=true
Administrator
Messages
Settings
Activity
Help
Find
Add Data
Explore Data
Monitoring Console
KNOWLEDGE
Searches, reports, and alerts
Data models
Event types
Tags
Fields
Lookups
User interface
Alert actions
Advanced search
All configurations
SYSTEM
Server settings
Server controls
Health report manager
RapidDiag
Instrumentation
Licensing
Workload management
DATA
Data inputs
Forwarding and receiving
Indexes
Report acceleration summaries
Virtual indexes
Source types
Ingest actions
DISTRIBUTED ENVIRONMENT
Indexer clustering
Forwarder management
Federated search
Distributed search
USERS AND AUTHENTICATION
Roles
Users
Tokens
Password Management
Authentication Methods


splunk download - Rech
Firefox Privacy Notice
Settings | Splunk
192.168.91.130:8000/en-US/manager/launcher/data/inputs/tcp/cooked/_new?action=edit&ns=launcher
splunk>enterprise
Apps
Administrator
Messages
Settings
Activity
Help
Find
Add new
Forwarding and receiving » Receive data » Add new
Configure receiving
Set up this Splunk instance to receive data from forwarder(s).
Listen on this port *
9997
For example, 9997 will receive data on TCP port 9997.
Cancel
Save

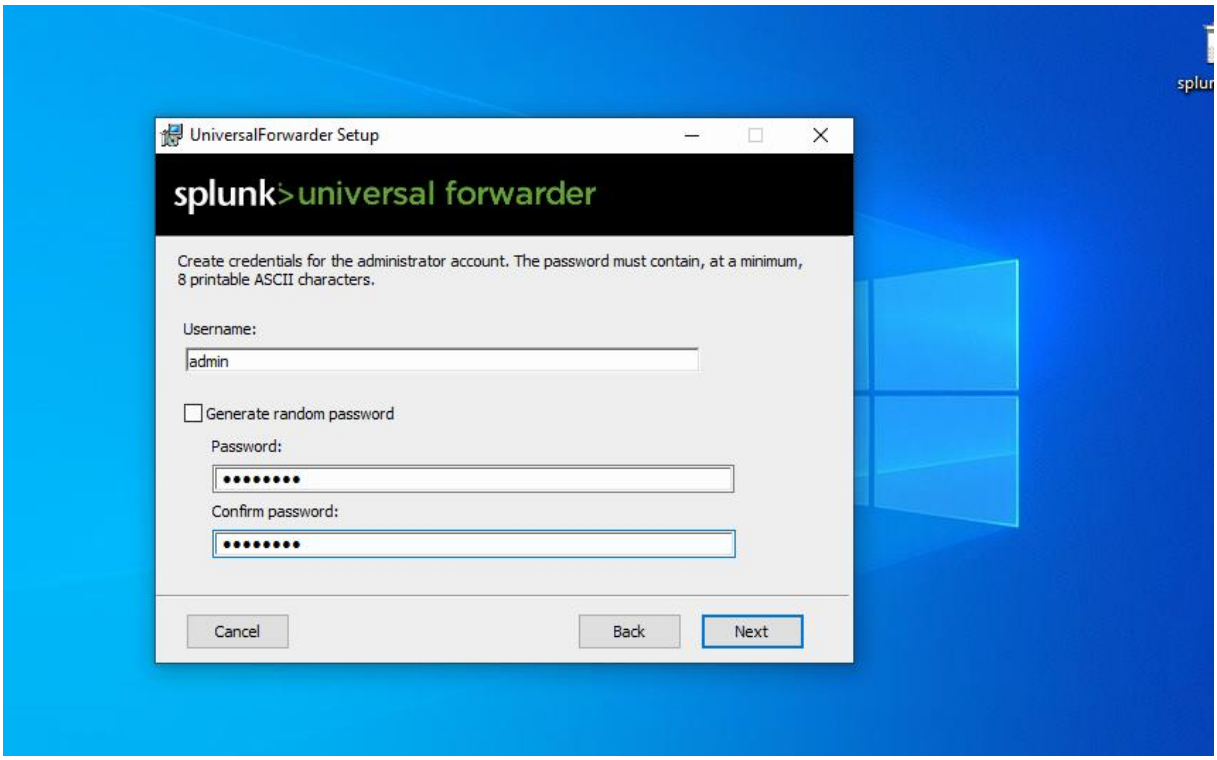
Une fois le port de réception configuré, nous passons à l'installation de l'agent chargé de collecter et de transférer les logs vers Splunk pour analyse.

Cet agent s'appelle **Splunk Forwarder**. Il est disponible sur la même page que **Splunk Enterprise**. Sur la machine Windows, on lance l'installation comme pour un exécutable classique. Pendant l'installation, on renseigne l'adresse IP du serveur Splunk.

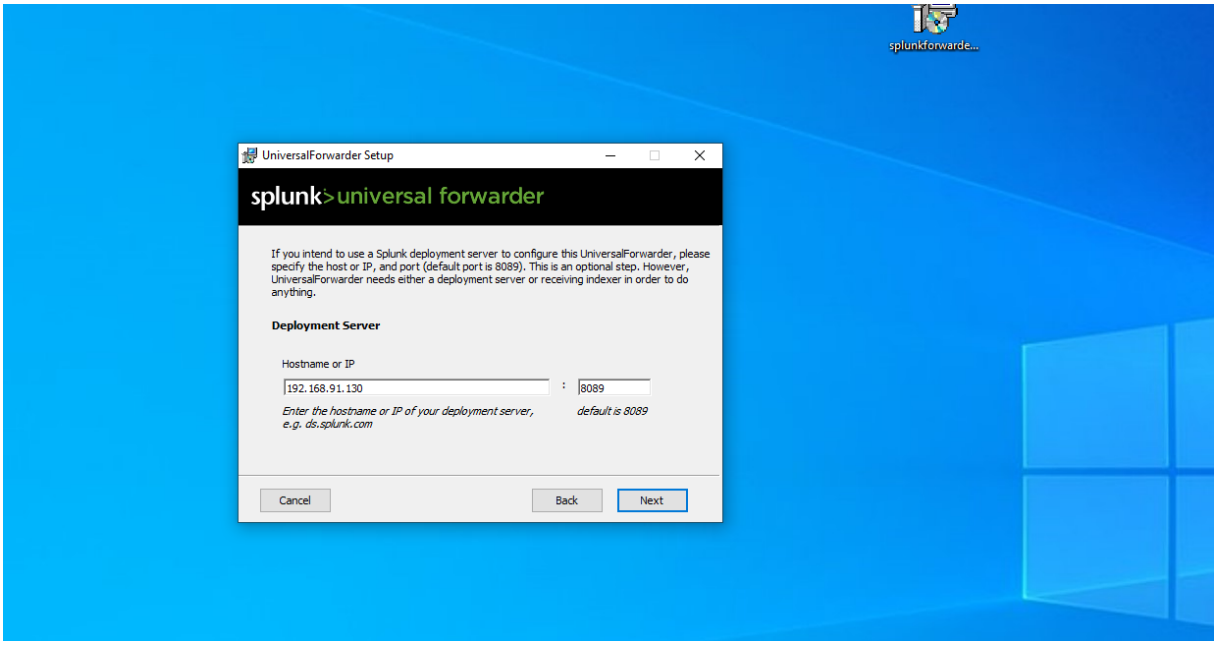
Après le lancement, on accepte les conditions, puis on clique sur **Next**.

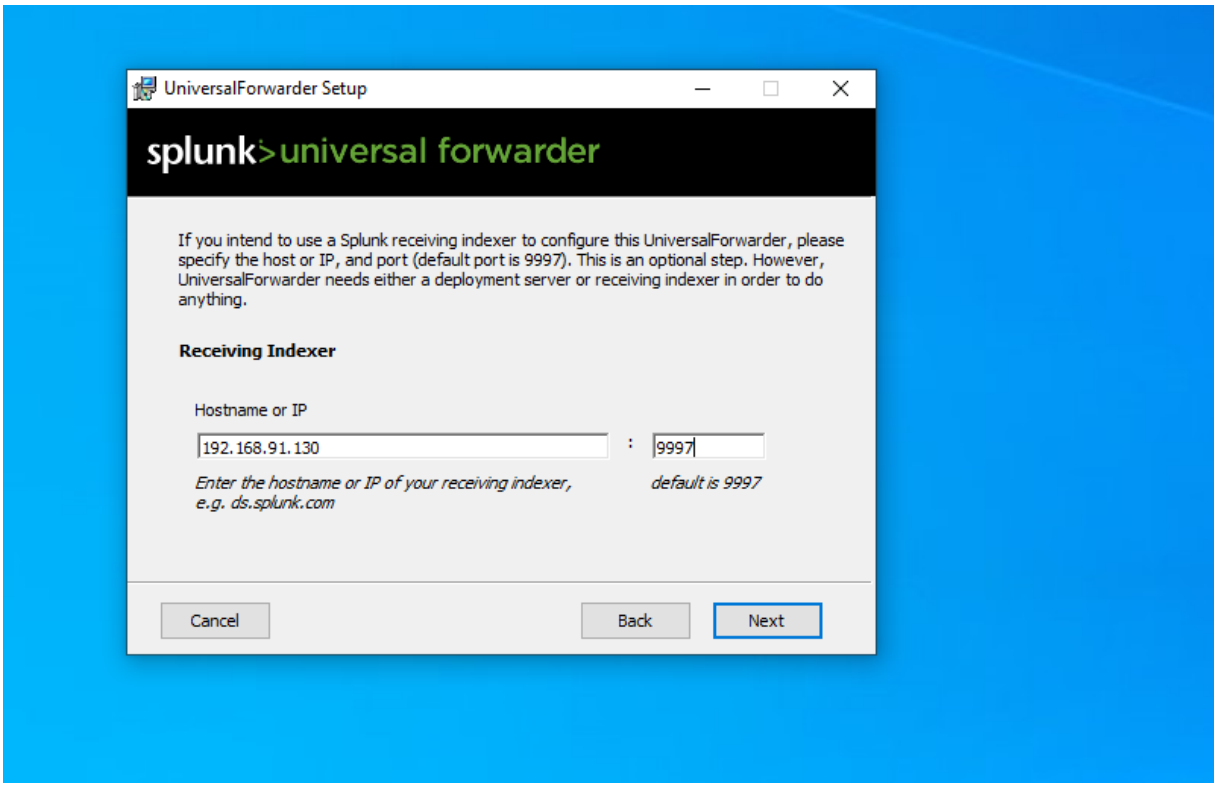


Ensuite on crée un compte comme sur l'image ci-après.

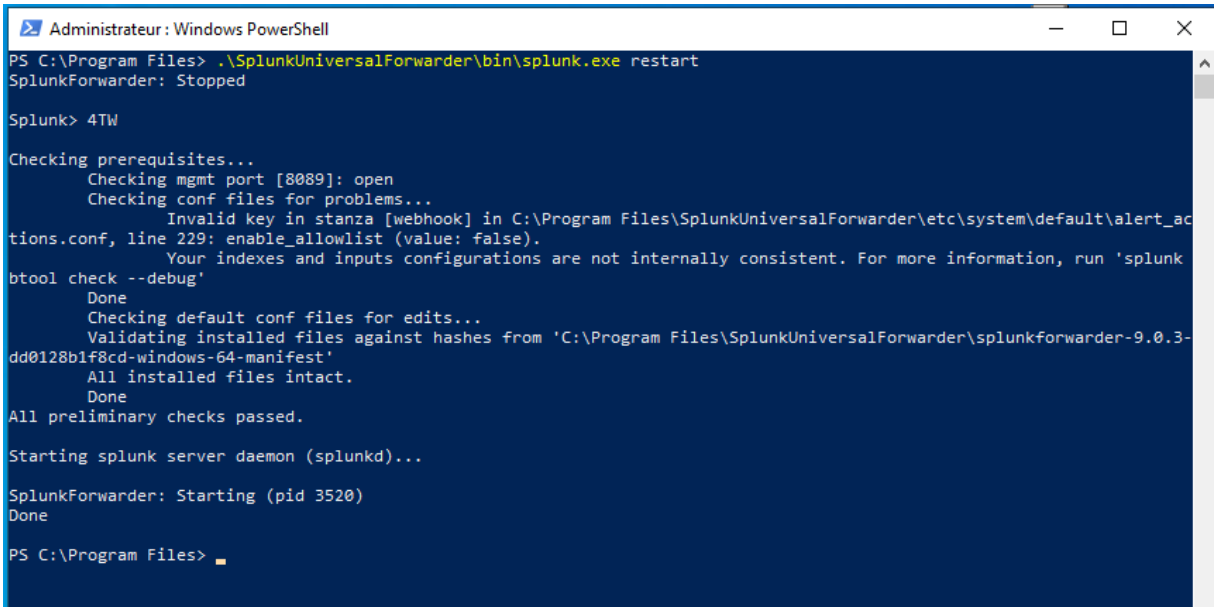


On renseigne l'adresse IP de notre serveur Splunk et le port comme sur les figures suivantes.

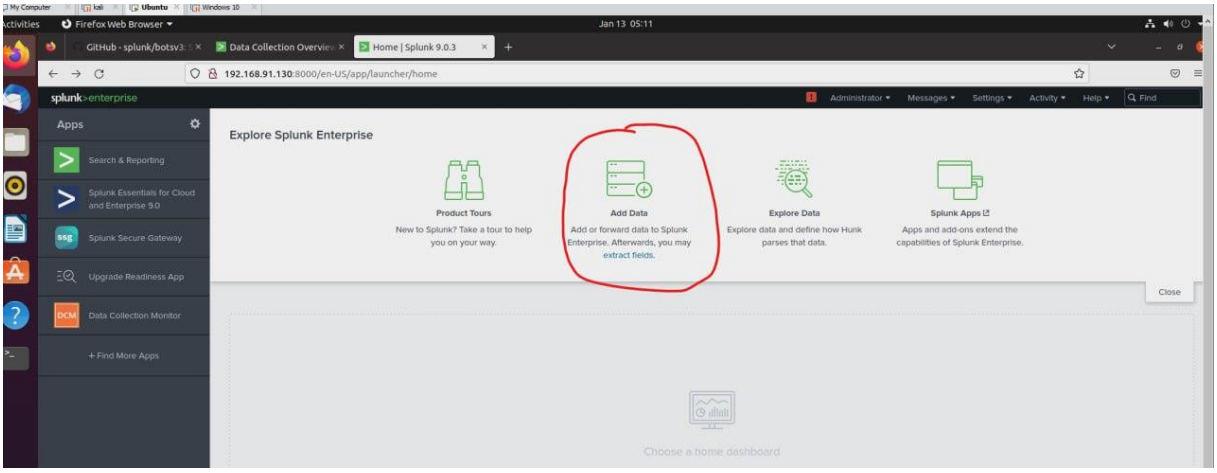




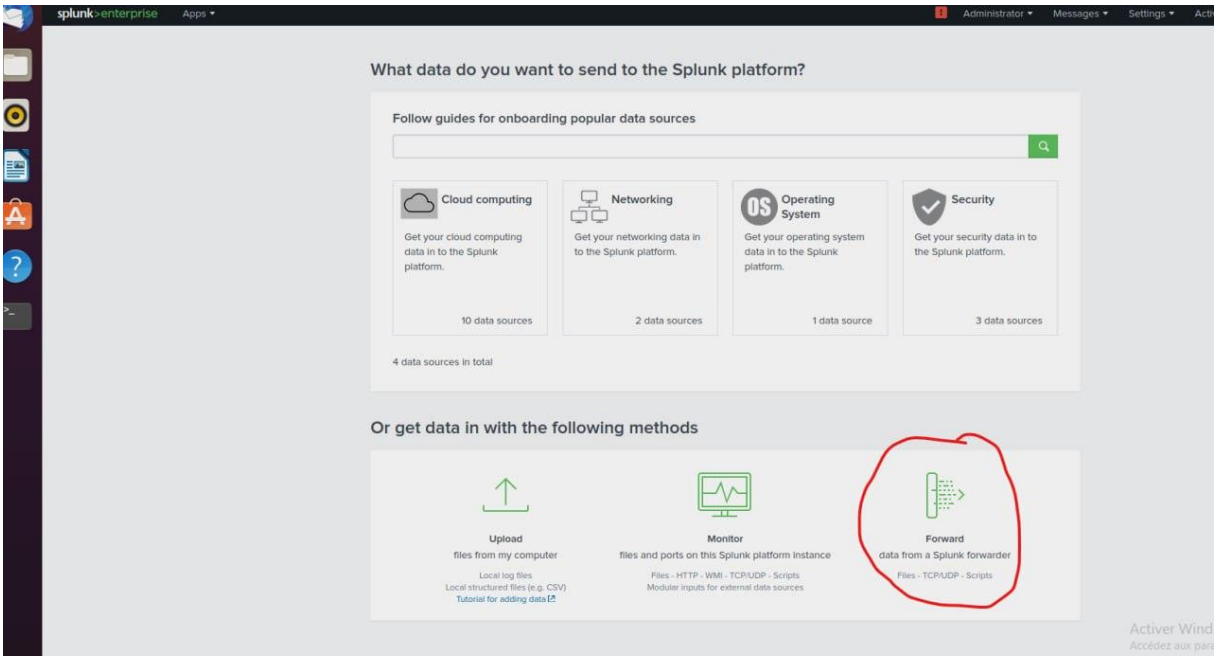
Ouvrons ensuite PowerShell et redémarrons le processus de l'agent comme sur l'image ci-dessous.



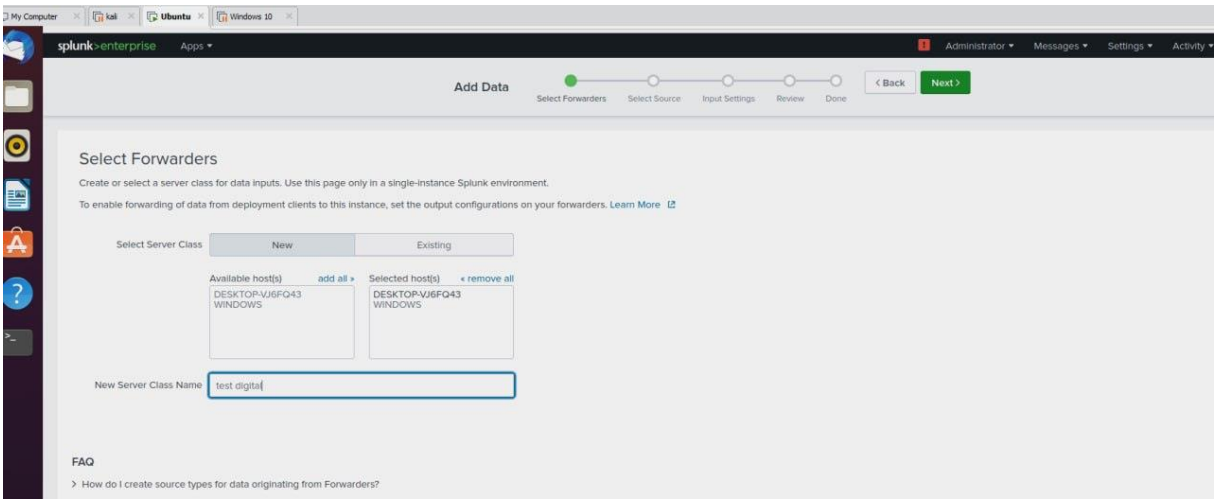
L'agent est prêt et fonctionnel. Il nous reste une configuration pour que Splunk reçoive les log. Connectons nous au serveur et ajoutons une source de donnée. Nous allons juste spécifier à notre serveur de recevoir les logs provenant de l'agent que nous avons mis en place. Sur la page d'accueil, on clique sur le bouton **Add Data**



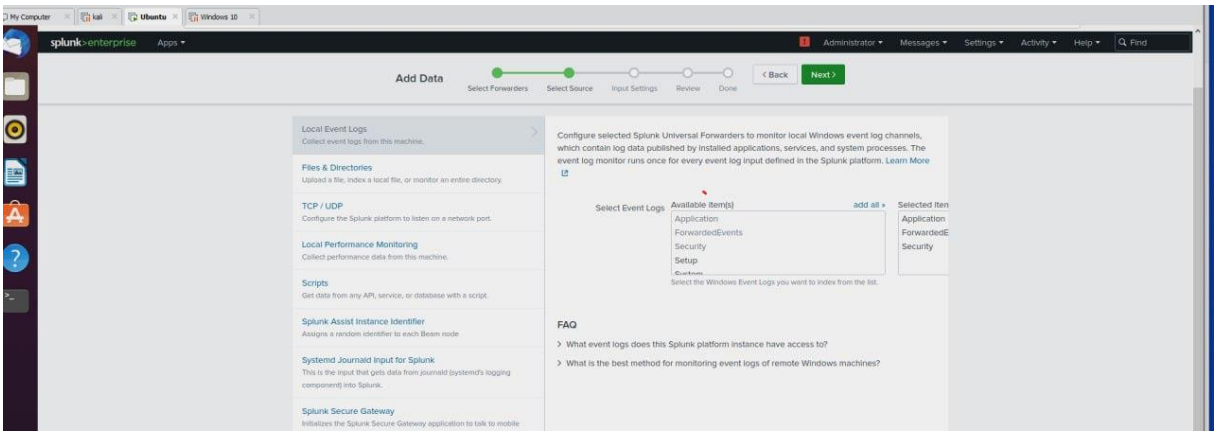
Sur la page suivante, un peu en bas, on sélectionne Forward (data from splunk forwader)



On obtient ainsi donc notre machine Windows sur laquelle nous avons déployé notre agent. On la sélectionne et on donne un nom comme sur l'image suivante.

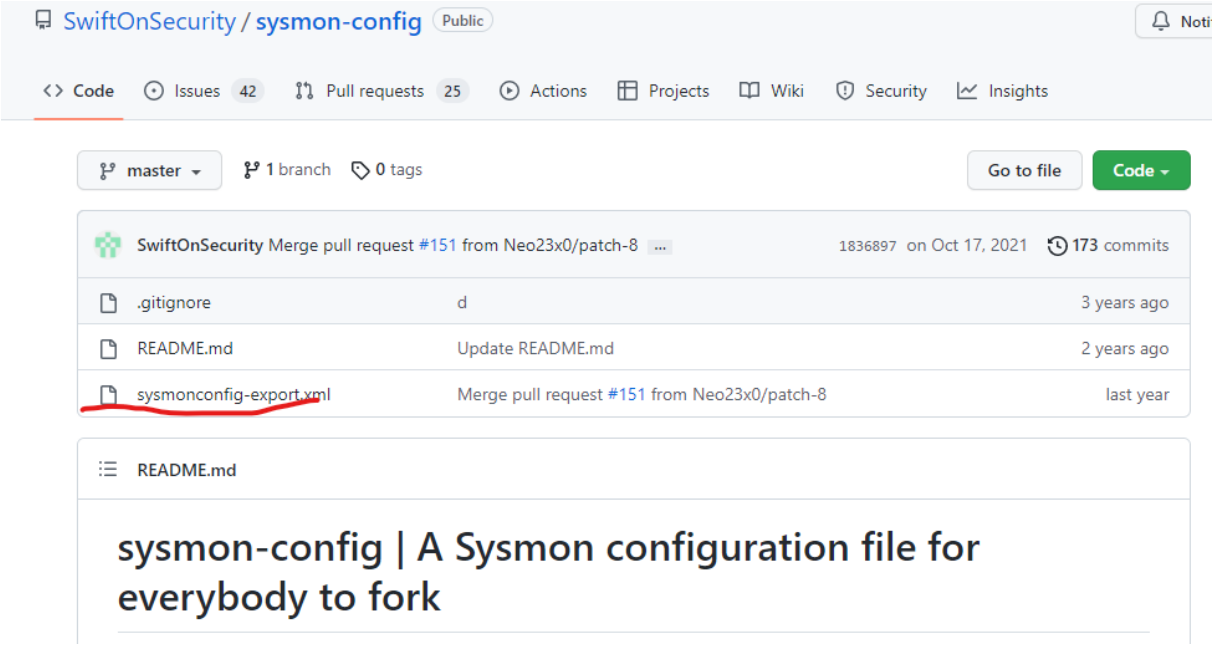


On clique sur **Next** pour sélectionner les données à collecter. Dans notre cas, on choisit **Local Event Logs**, puis on sélectionne les événements.



Faisons, **Next** jusqu'à la fin pour valider la configuration.

Pour collecter davantage de données, nous avons installé **Sysmon** sur la machine Windows et l'avons configuré comme source (*input*) au niveau de l'agent. Pour obtenir Sysmon, il suffit de le télécharger depuis le site de Microsoft à travers ce lien sysmon. Ensuite, nous utilisons le fichier de configuration **SwiftOnSecurity**, disponible sur github.



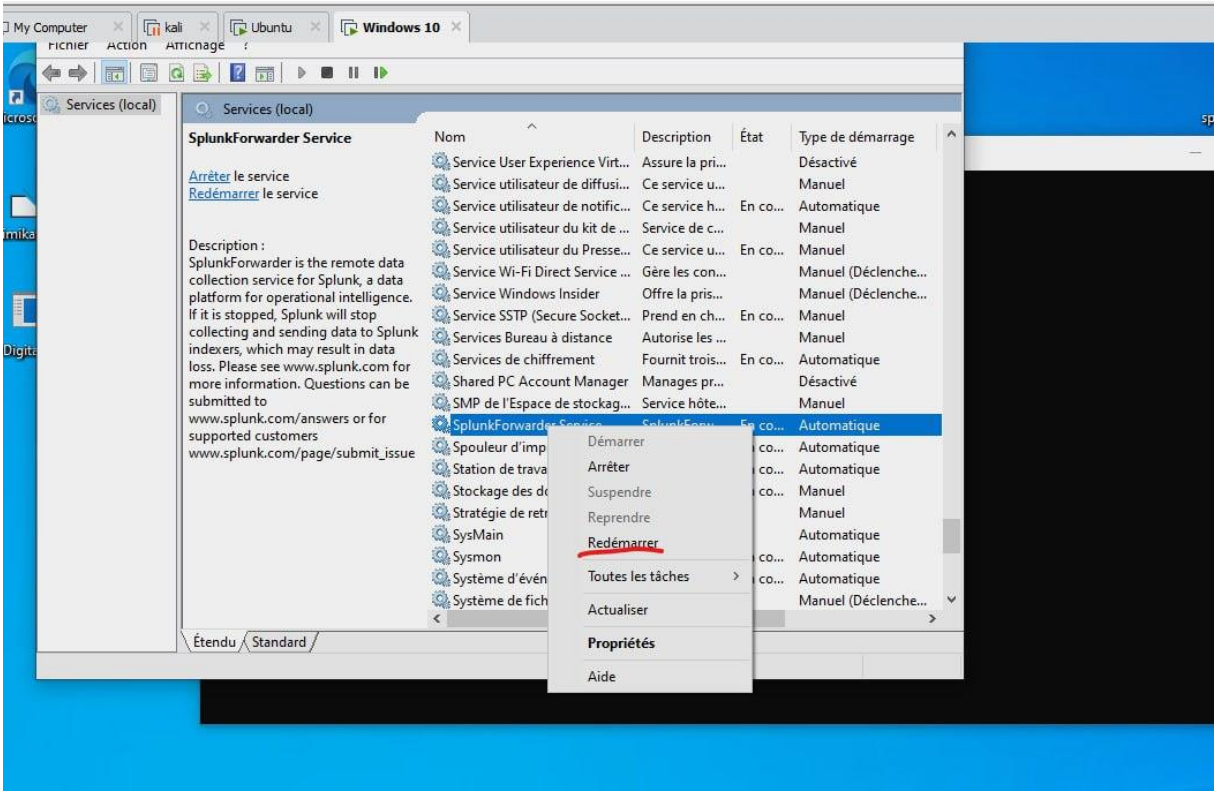
Déplaçons-nous dans le répertoire de sysmon et exécutons la commande sur l'image suivante pour l'installation.

```
Administrateur : Windows PowerShell
PS C:\Users\HP\Downloads\Sysmon> ls


    Répertoire : C:\Users\HP\Downloads\Sysmon


Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-a----        09/01/2023     16:05           7490 Eula.txt
-a----        09/01/2023     16:05        8192784 Sysmon.exe
-a----        09/01/2023     16:05        4421432 Sysmon64.exe
-a----        09/01/2023     16:05        4793104 Sysmon64a.exe
-a----        09/01/2023     16:05         123257 sysmonconfig-export.xml


PS C:\Users\HP\Downloads\Sysmon> .\Sysmon.exe -i .\sysmonconfig-export.xml -accepteula


System Monitor v14.13 - System activity monitor
By Mark Russinovich and Thomas Garnier
Copyright (C) 2014-2022 Microsoft Corporation
Using libxml2. libxml2 is Copyright (C) 1998-2012 Daniel Veillard. All Rights Reserved.
Sysinternals - www.sysinternals.com

Loading configuration file with schema version 4.50
Sysmon schema version: 4.83
Configuration file validated.
Sysmon installed.
SysmonDrv installed.
Starting SysmonDrv.
SysmonDrv started.
Starting Sysmon..
Sysmon started.
PS C:\Users\HP\Downloads\Sysmon>
```

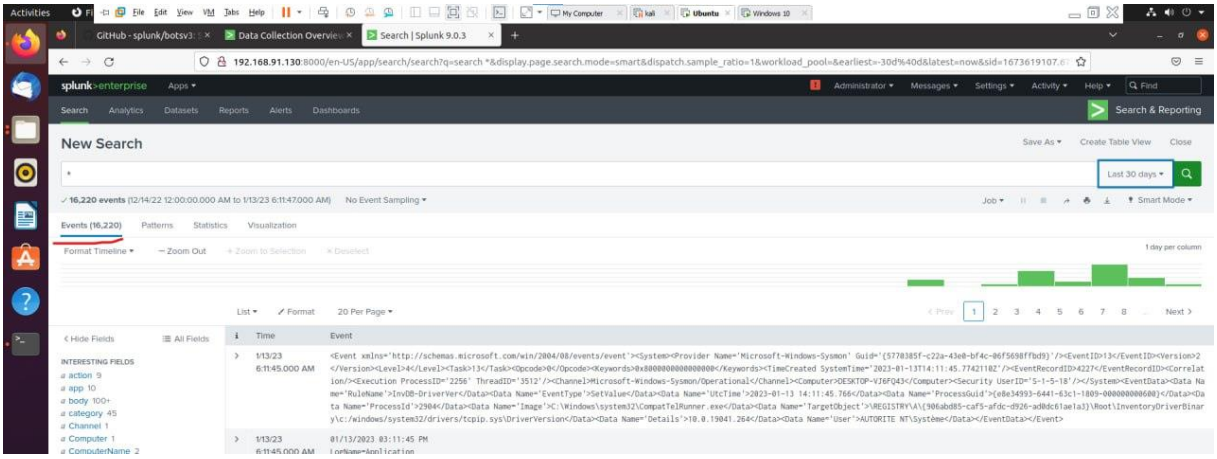
Copions ce bout de code dans le fichier des **inputs** se trouvant dans le répertoire d'installation de l'agent Splunk.

```
[WinEventLog://Microsoft-Windows-Sysmon/Operational]
disabled = false
renderXml = true
source = XmlWinEventLog:Microsoft-Windows-Sysmon/Operational
```

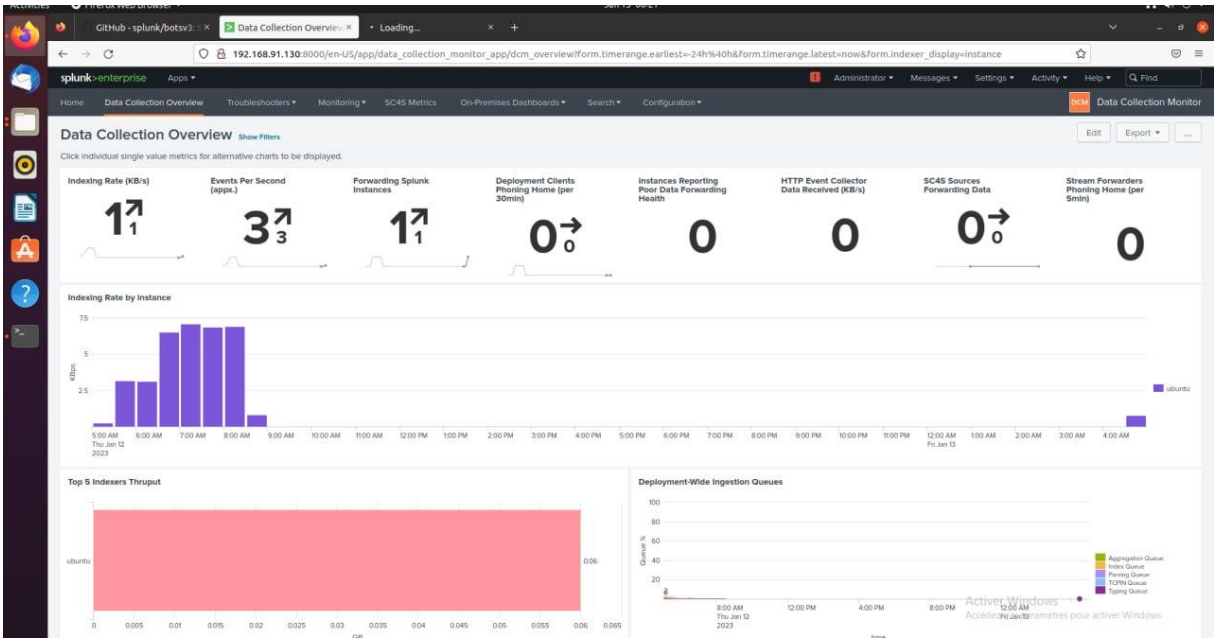
Notre splunk devra commencer pas recevoir des logs. Mais avant, on redémarre le service.



Retournons sur splunk dans la section **search & reporting** et voyons si nous récupérons quelque chose. Faisons juste une recherche complète avec « * » et voyons la sortie. On voit bien sur la photo qu'on a reçu environ **16000 logs.**



Ci-dessous un aperçu des logs sous forme de graphes.



Avec **Splunk**, nous pouvons mener des investigations sur des événements spécifiques à partir des sources de données collectées.

Pour cela, nous générons des logs à l'aide de **Atomic Red Team**, un outil open source permettant d'évaluer la détection et la réponse aux menaces. Il simule des attaques basées sur des techniques réelles utilisées par les attaquants afin de tester les outils de sécurité et identifier les failles.

Nous utilisons Invoke atomic red team pour simuler ces comportements sur la machine cible. L'objectif est de générer des logs et d'analyser la réaction de Splunk face à ces événements.

Pour commencer, nous installons l'outil en suivant la documentation officielle. Depuis **PowerShell**, nous exécutons les commandes indiquées, comme illustré sur l'image suivante.

```
Administrateur : Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. Tous droits réservés.

Testez le nouveau système multiplateforme PowerShell https://aka.ms/pscore6

PS C:\Windows\system32>
PS C:\Windows\system32>
PS C:\Windows\system32> Install-Module -Name invoke-atomicredteam,powershell-yaml -Scope CurrentUser

Le fournisseur NuGet est requis pour continuer
PowerShellGet requiert le fournisseur NuGet, version 2.8.5.201 ou ultérieure, pour interagir avec les référentiels
NuGet. Le fournisseur NuGet doit être disponible dans « C:\Program Files\PackageManagement\ProviderAssemblies » ou «
C:\Users\HP\AppData\Local\PackageManagement\ProviderAssemblies ». Vous pouvez également installer le fournisseur NuGet
en exécutant la commande « Install-PackageProvider -Name NuGet -MinimumVersion 2.8.5.201 -Force ». Voulez-vous que
PowerShellGet installe et importe le fournisseur NuGet maintenant ?
[O] Oui  [N] Non  [S] Suspendre  [?] Aide (la valeur par défaut est « O ») : o

Référentiel non approuvé
Vous installez les modules à partir d'un référentiel non approuvé. Si vous approuvez ce référentiel, modifiez sa valeur
 InstallationPolicy en exécutant l'applet de commande Set-PSRepository. Voulez-vous vraiment installer les modules à
partir de PSGallery ?
[O] Oui  [T] Oui pour tout  [N] Non  [U] Non pour tout  [S] Suspendre  [?] Aide (la valeur par défaut est « N ») : o
PS C:\Windows\system32>
```

On importe les modules contenant les scripts, puis on effectue un test. On constate que tout est fonctionnel en exécutant une technique **MITRE ATT&CK** (T1218).

```
PS C:\Windows\system32> Import-Module "C:\AtomicRedTeam\invoke-atomicredteam\Invoke-AtomicRedTeam.psd1" -Force
PS C:\Windows\system32> Invoke-AtomicTest t1218 -showdetailsbrief
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

T1218-1 mavinject - Inject DLL into running process
T1218-2 Register-CimProvider - Execute evil dll
T1218-3 InfDefaultInstall.exe .inf Execution
T1218-4 ProtocolHandler.exe Downloaded a Suspicious File
T1218-5 Microsoft.Workflow.Compiler.exe Payload Execution
T1218-6 Renamed Microsoft.Workflow.Compiler.exe Payload Executions
T1218-7 Invoke-ATHRemoteFXvGPUDisablementCommand base test
T1218-8 DiskShadow Command Execution
T1218-9 Load Arbitrary DLL via Wuauclt (Windows Update Client)
T1218-10 Lolbin Gpscript logon option
T1218-11 Lolbin Gpscript startup option
T1218-12 Lolbas ie4uinit.exe use as proxy
PS C:\Windows\system32> Invoke-AtomicTest T1003 -ShowDetailsBrief
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

T1003-1 Gsecdump
T1003-2 Credential Dumping with NPPSpy
T1003-3 Dump svchost.exe to gather RDP credentials
T1003-4 Retrieve Microsoft IIS Service Account Credentials Using AppCmd (using list)
T1003-5 Retrieve Microsoft IIS Service Account Credentials Using AppCmd (using config)
T1003-6 Dump Credential Manager using keymgr.dll and rundll32.exe
PS C:\Windows\system32> Invoke-AtomicTest All -ShowDetailsBrief
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

T1003-1 Gsecdump
```

Nous allons maintenant générer un ensemble de logs à l'aide de notre outil. Pour cela, nous exécutons les techniques disponibles via la commande indiquée sur l'image.

Des attaques simulées sont alors lancées, et les logs sont automatiquement envoyés vers **Splunk**.

```
T1003-5 Retrieve Microsoft IIS Service Account Credentials Using AppCmd (using config)
T1003-6 Dump Credential Manager using keymgr.dll and rundll32.exe
PS C:\Windows\system32> Invoke-AtomicTest All -ShowDetailsBrief
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

T1003-1 Gsecdump
```

```
T1003-1 Gsecdump
T1003-2 Credential Dumping with NPPSpy
T1003-3 Dump svchost.exe to gather RDP credentials
T1003-4 Retrieve Microsoft IIS Service Account Credentials Using AppCmd (using list)
T1003-5 Retrieve Microsoft IIS Service Account Credentials Using AppCmd (using config)
T1003-6 Dump Credential Manager using keymgr.dll and rundll32.exe
T1003.001-1 Dump LSASS.exe Memory using ProcDump
T1003.001-2 Dump LSASS.exe Memory using comsvcs.dll
T1003.001-3 Dump LSASS.exe Memory using direct system calls and API unhooking
T1003.001-4 Dump LSASS.exe Memory using NanoDump
T1003.001-6 Offline Credential Theft With Mimikatz
T1003.001-7 LSASS read with pypykatz
T1003.001-8 Dump LSASS.exe Memory using Out-Minidump.ps1
T1003.001-9 Create Mini Dump of LSASS.exe using ProcDump
T1003.001-10 Powershell Mimikatz
T1003.001-11 Dump LSASS with .Net 5 createdump.exe
T1003.001-12 Dump LSASS.exe using imported Microsoft DLLs
T1003.002-1 Registry dump of SAM, creds, and secrets
T1003.002-2 Registry parse with pypykatz
T1003.002-3 esentutl.exe SAM copy
T1003.002-4 PowerDump Hashes and Usernames from Registry
T1003.002-5 dump volume shadow copy hives with certutil
T1003.002-6 dump volume shadow copy hives with System.IO.File
T1003.002-7 WinPwn - Loot local Credentials - Dump SAM-File for NTLM Hashes
T1003.003-1 Create Volume Shadow Copy with vssadmin
T1003.003-2 Copy NTDS.dit from Volume Shadow Copy
T1003.003-3 Dump Active Directory Database with NTDSUtil
T1003.003-4 Create Volume Shadow Copy with WMI
T1003.003-5 Create Volume Shadow Copy remotely with WMI
T1003.003-6 Create Volume Shadow Copy remotely (WMI) with esentutl
T1003.003-7 Create Volume Shadow Copy with Powershell
```

Parmi les logs récupérés, certains sont liés aux actions de notre outil. Comme mentionné précédemment, son rôle principal est de réaliser un audit du système cible.

Pendant cet audit, il collecte des informations spécifiques. On peut voir sur l'image qu'une opération d'énumération a été effectuée avec succès sur la machine.

Splunk fournit alors toutes les informations associées à cet événement.

```
> 1/13/23          01/13/2023 03:27:19 PM
  6:27:19.000 AM   LogName=Security
                   EventCode=5379
                   EventType=0
                   ComputerName=DESKTOP-VJ6FQ43
                   SourceName=Microsoft Windows security auditing.
                   Type=Information
                   RecordNumber=3285
                   Keywords=Succès de l'audit
                   TaskCategory=User Account Management
                   OpCode=Informations
                   Message=Les informations d'identification du Gestionnaire d'informations d'identification ont été lues.

                   Sujet :
                           ID de sécurité :                S-1-5-21-3512764293-575791123-3739389287-1001
                           Nom du compte :         HP
                           Domaine de comptes :            DESKTOP-VJ6FQ43
                           ID d'ouverture de session :             0x167B25
                           Opération de lecture :          Énumérer les informations d'identification

                   Cet événement se produit lorsqu'un utilisateur exécute une opération de lecture sur des informations d'identification stockées dans le Gestionnaire d'informations d'identification.
                   Collapse
```

Ici un utilisateur a été supprimé.

```
> 1/8/23          01/09/2023 08:23:27 AM
  11:23:27.000 PM LogName=Security
                  EventCode=4726
                  EventType=0
                  ComputerName=DESKTOP-VJ6FQ43
                  SourceName=Microsoft Windows security auditing.
                  Type=Information
                  RecordNumber=653
                  Keywords=Succès de l'audit
                  TaskCategory=User Account Management
                  OpCode=Informations
                  Message=Un compte d'utilisateur a été supprimé.

                  Sujet :
                          ID de sécurité :                S-1-5-21-3512764293-575791123-3739389287-1001
                          Nom du compte :         HP
                          Domaine du compte :             DESKTOP-VJ6FQ43
                          ID d'ouverture de session :             0x2D65C

                  Compte cible :
                          ID de sécurité :                S-1-5-21-3512764293-575791123-3739389287-1000
                          Nom du compte :         defaultuser0
                          Domaine du compte :             DESKTOP-VJ6FQ43

                  Informations supplémentaires :
                          Privilèges      -
                  Collapse
```

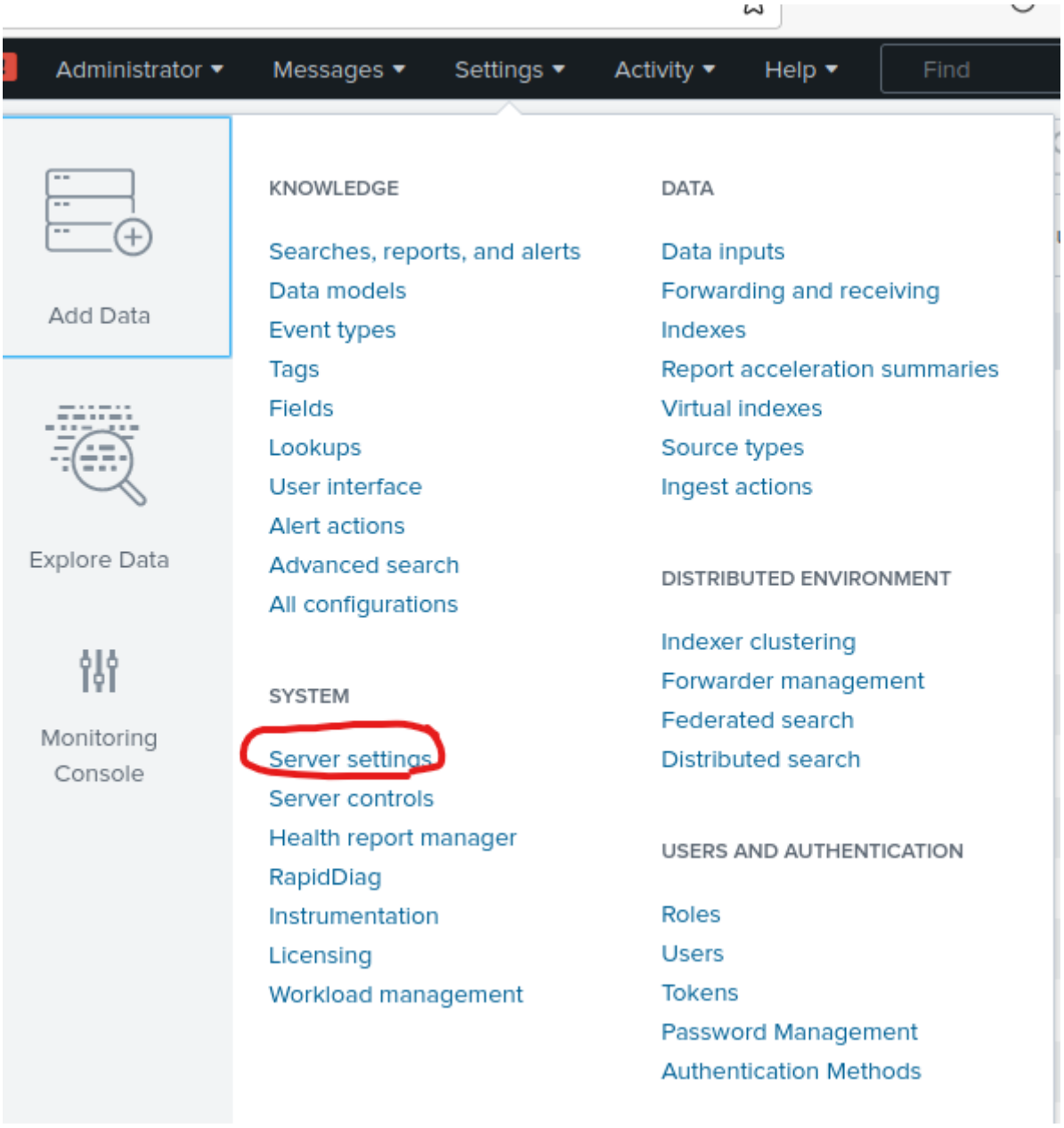
Activer Windows

À travers ces étapes, nous avons montré comment mettre en place **Splunk** et utiliser ses agents pour collecter des événements utiles aux investigations en cas d'incident.

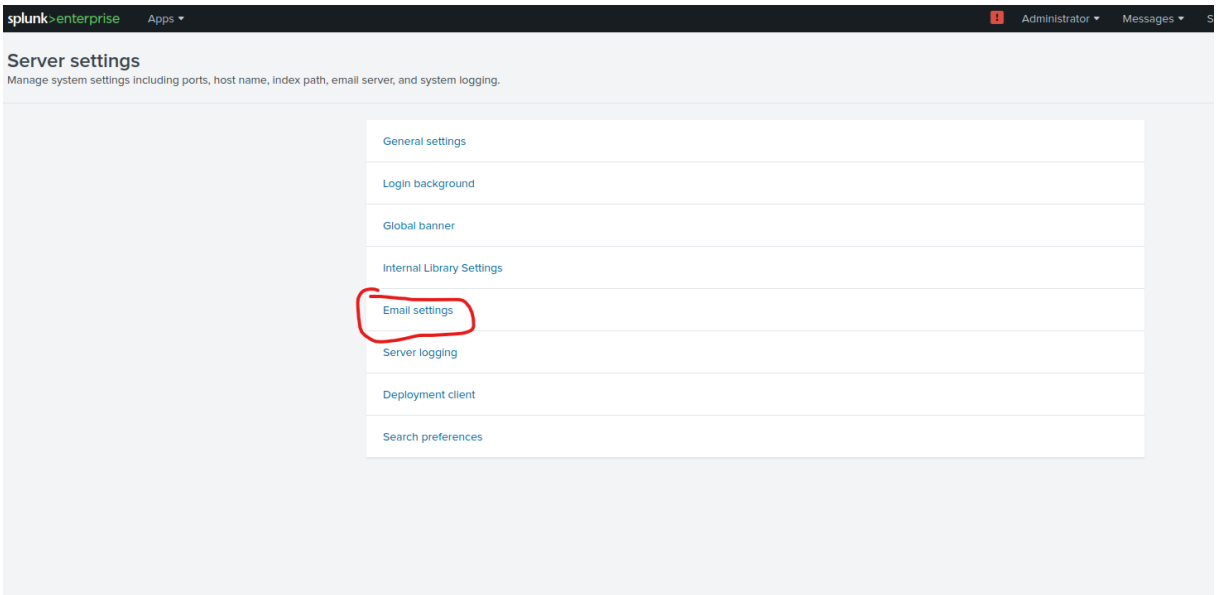
Création d'alerte

Après la collecte des événements, il est possible de créer des alertes spécifiques liées à certaines menaces ou activités suspectes pouvant compromettre le système.

Pour cela, il faut d'abord configurer les paramètres de messagerie dans **Splunk**. On se rend dans **Settings**, puis on clique sur **Server Settings**, comme illustré sur l'image ci-dessous.



Sur la page qui s'affiche, on clique sur **Email setting.** L'objectif sera de configurer les paramètres de la boite de messagerie que nous utilisons.

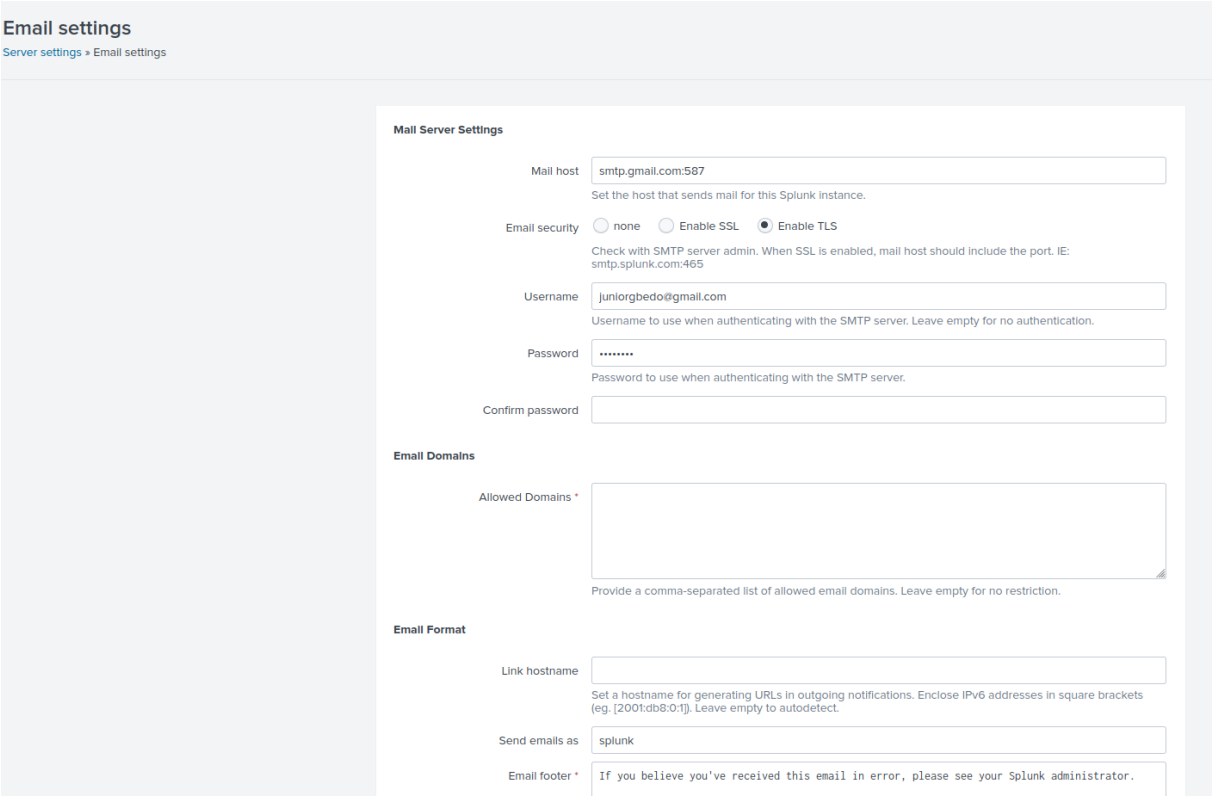


Sur la prochaine page, on remplit les informations comme sur l'image suivante :

Mail host : smtp.gmail.com:587 (parce ce que c'est Gmail nous utilisons comme messagerie électronique) et nous cochons **enable TLS**

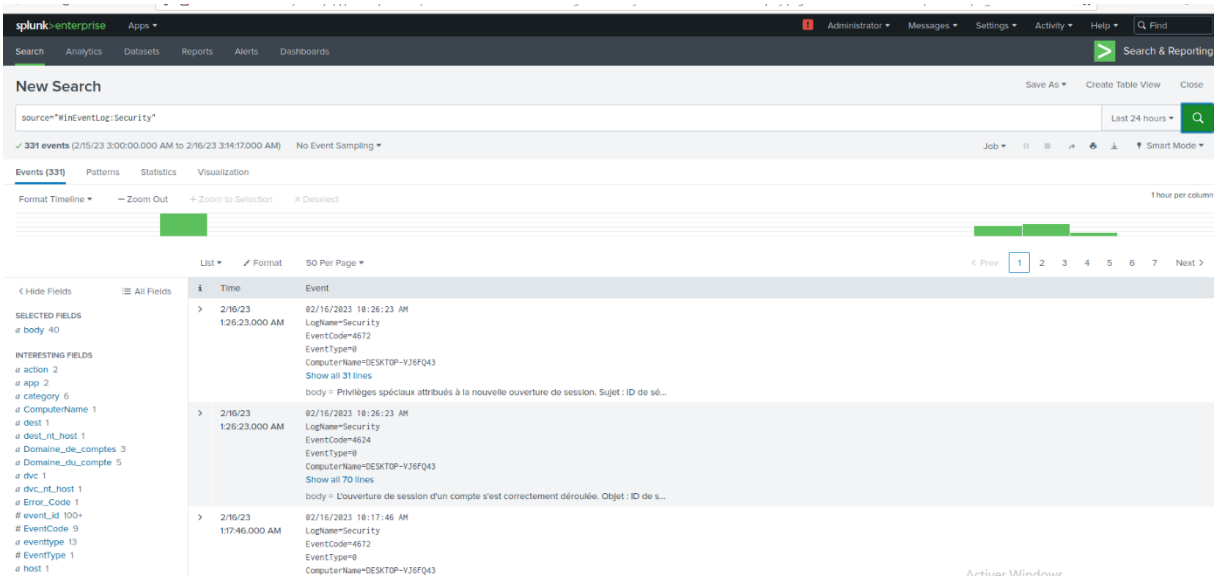
Username : Nous mettons l'adresse mail de l'administrateur qui est censé recevoir les alertes

Password: On spécifie ici le mot de passe qu'il utilise pour se connecter. Splunk l'utilisera pour authentification

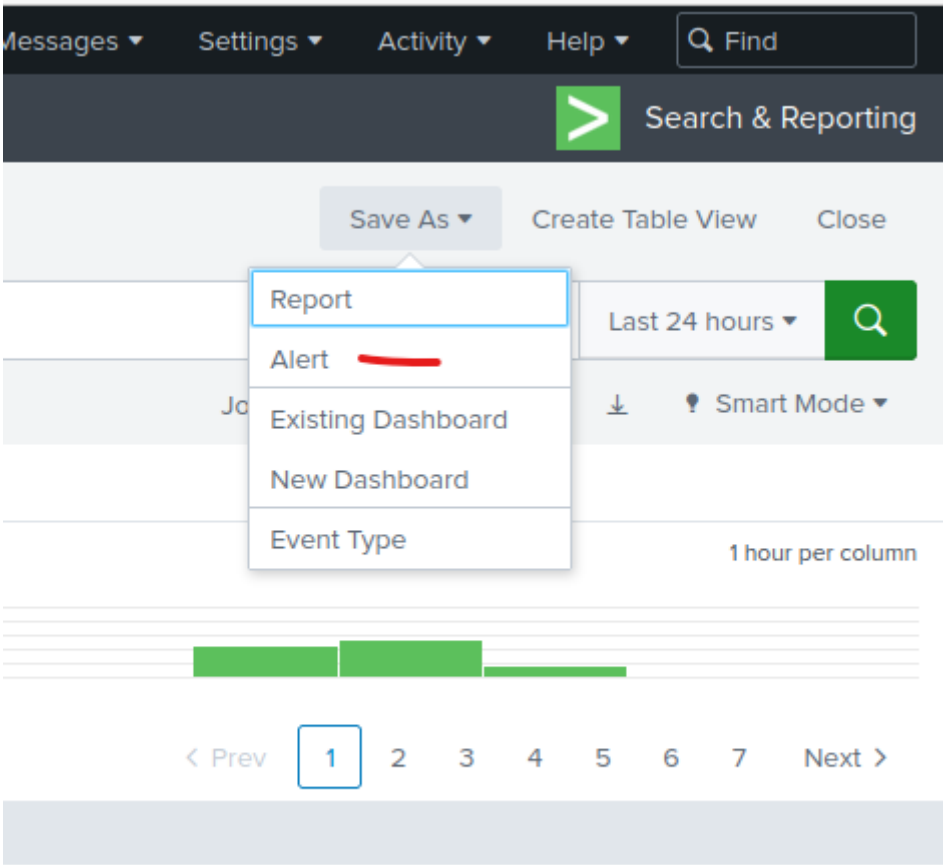


Voici les principales configurations. Il suffit ensuite de défiler vers le bas et de sauvegarder.

Nous pouvons maintenant créer une alerte. Pour cela, on se rend dans la section de recherche des événements. Comme illustré sur la figure suivante, nous recherchons les événements de sécurité sur la machine Windows. Il est également possible de créer des alertes spécifiques, par exemple pour détecter des ransomwares. Les configurations dépendent des besoins et des menaces ciblées.

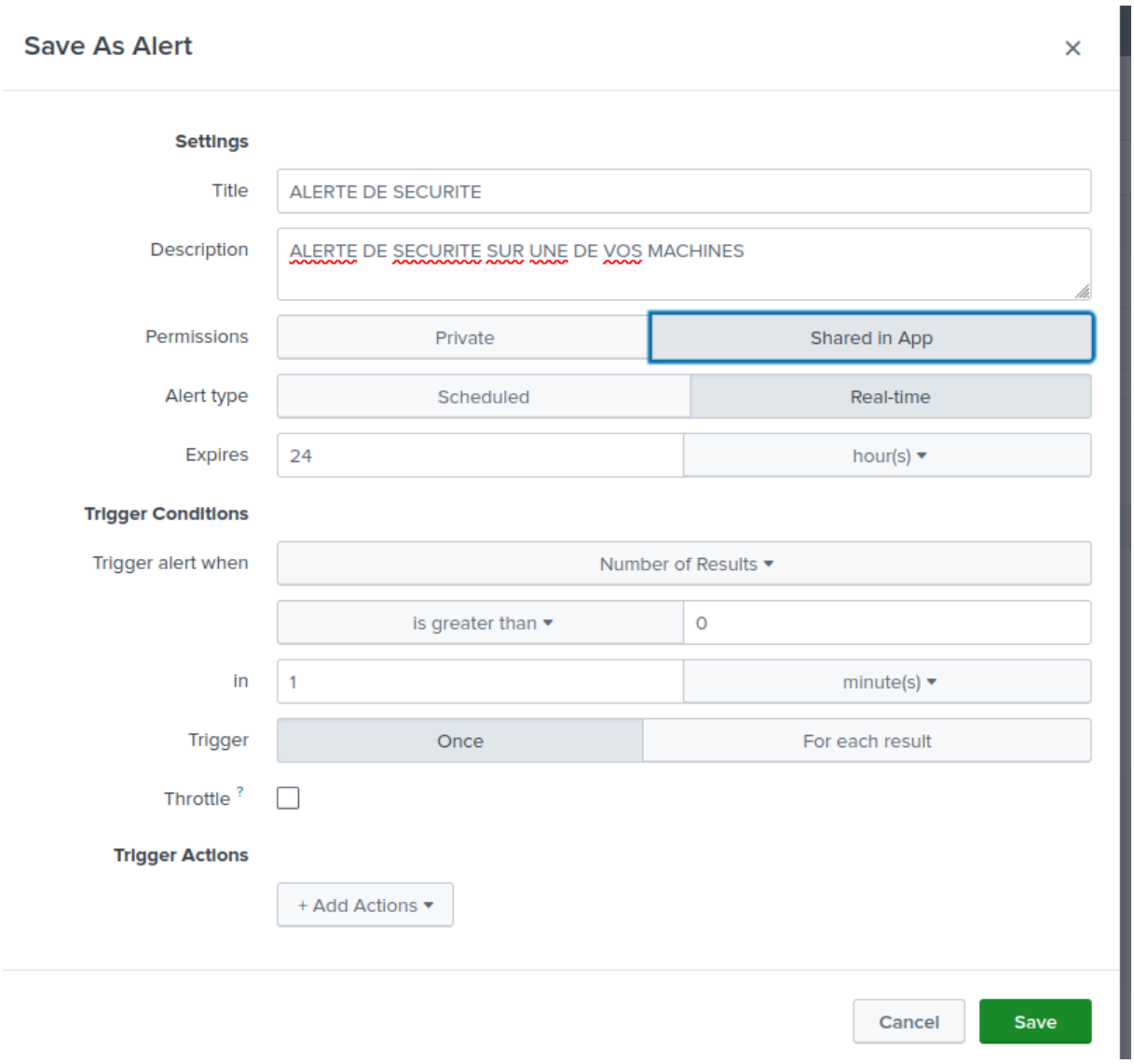


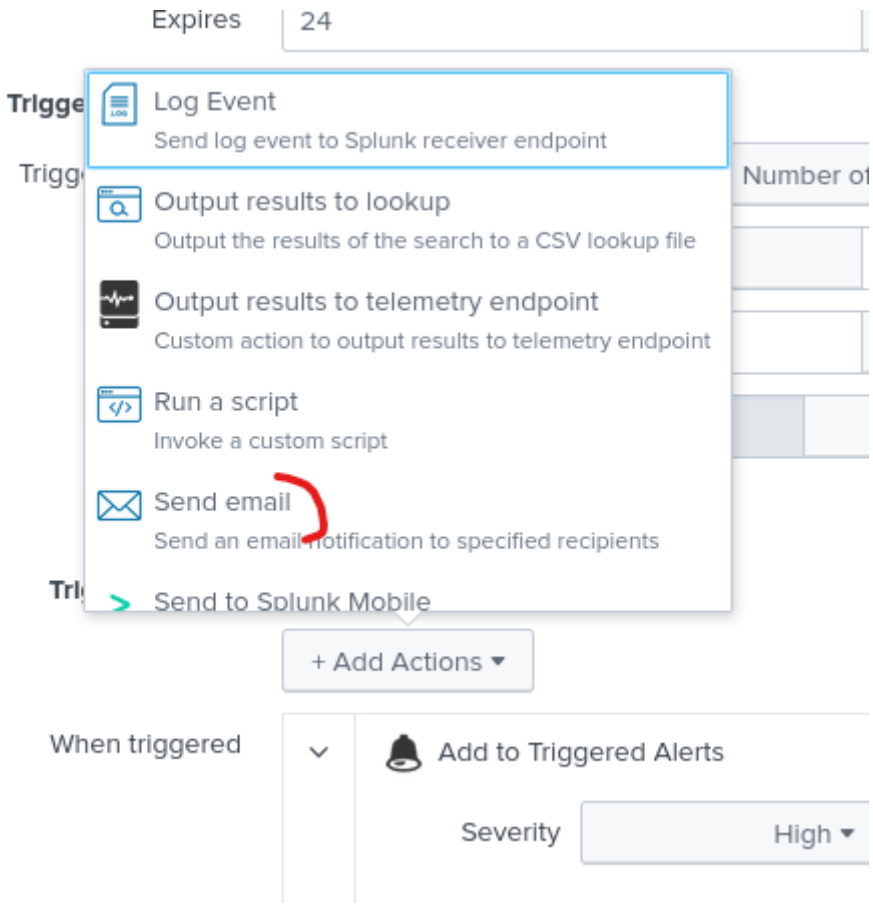
Dans l'angle supérieur droit on fait **Save as** et on choisit **alerte.**



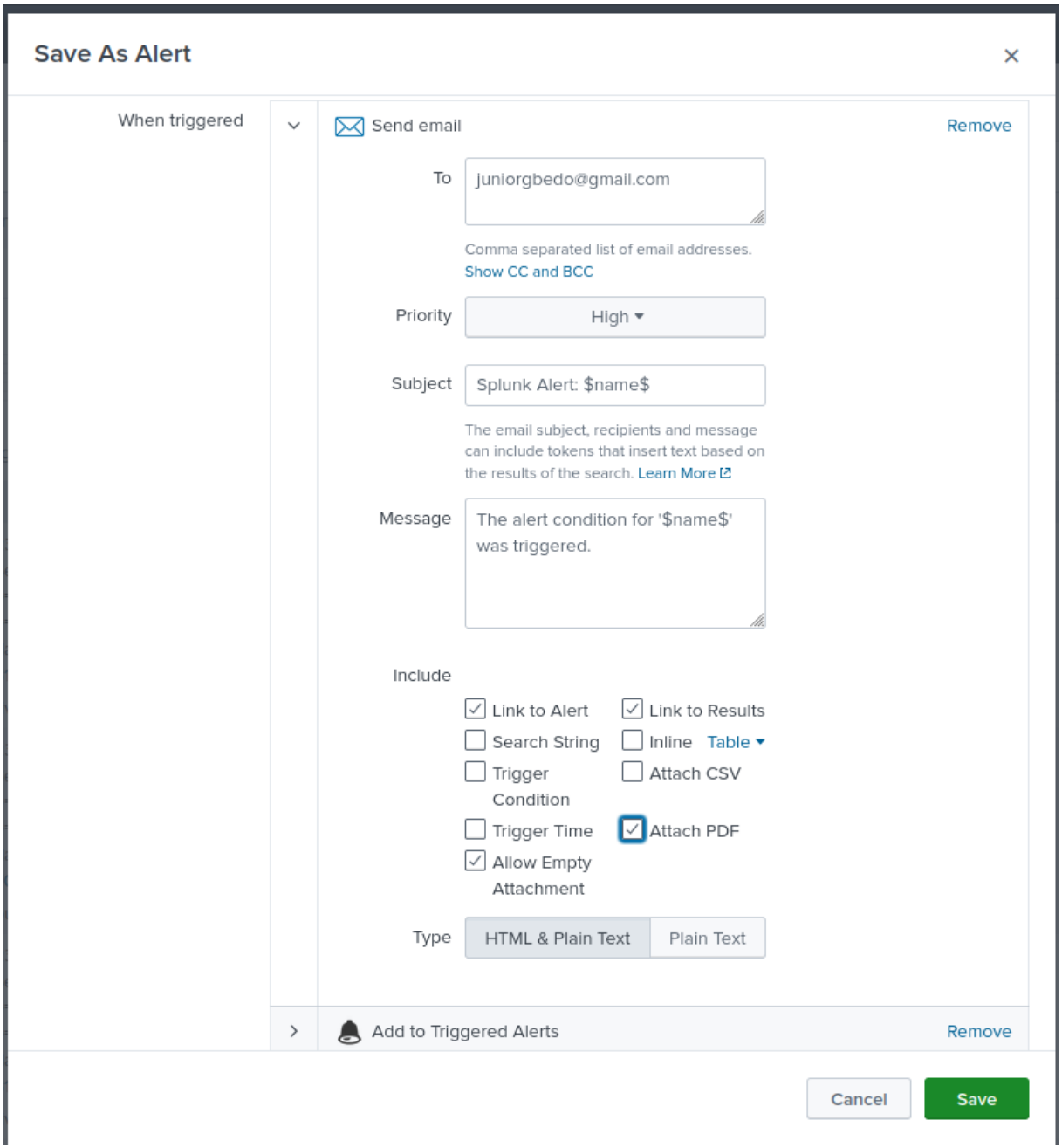
La fenêtre qui s'affiche permet de configurer les paramètres de l'alerte :

- **Settings** : on définit le titre et la description de l'alerte, les permissions, ainsi que le mode d'exécution. Dans notre cas, nous choisissons **Real-time**. On peut également définir une date d'expiration.
- **Trigger Condition** : on précise la condition de déclenchement de l'alerte (par exemple, lorsque le nombre de résultats est supérieur à zéro).
- **Trigger Action** : on configure les actions à exécuter, comme l'affichage de l'alerte dans le panneau dédié et l'envoi d'une notification par email.

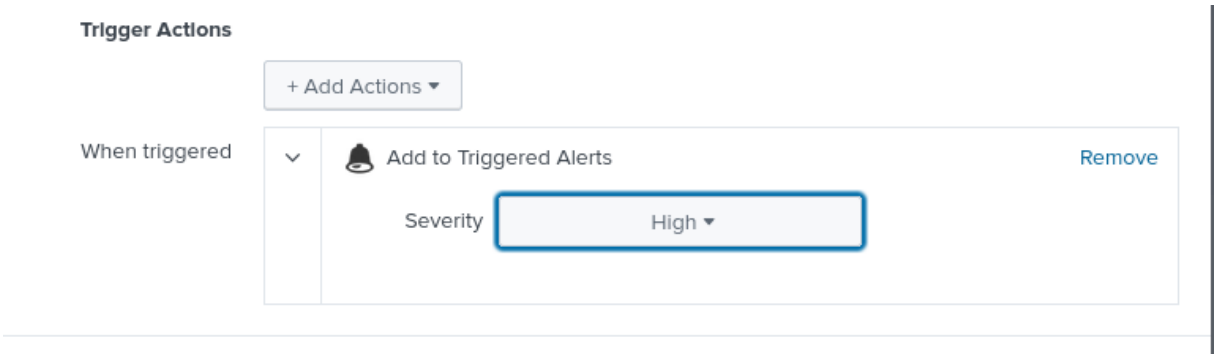




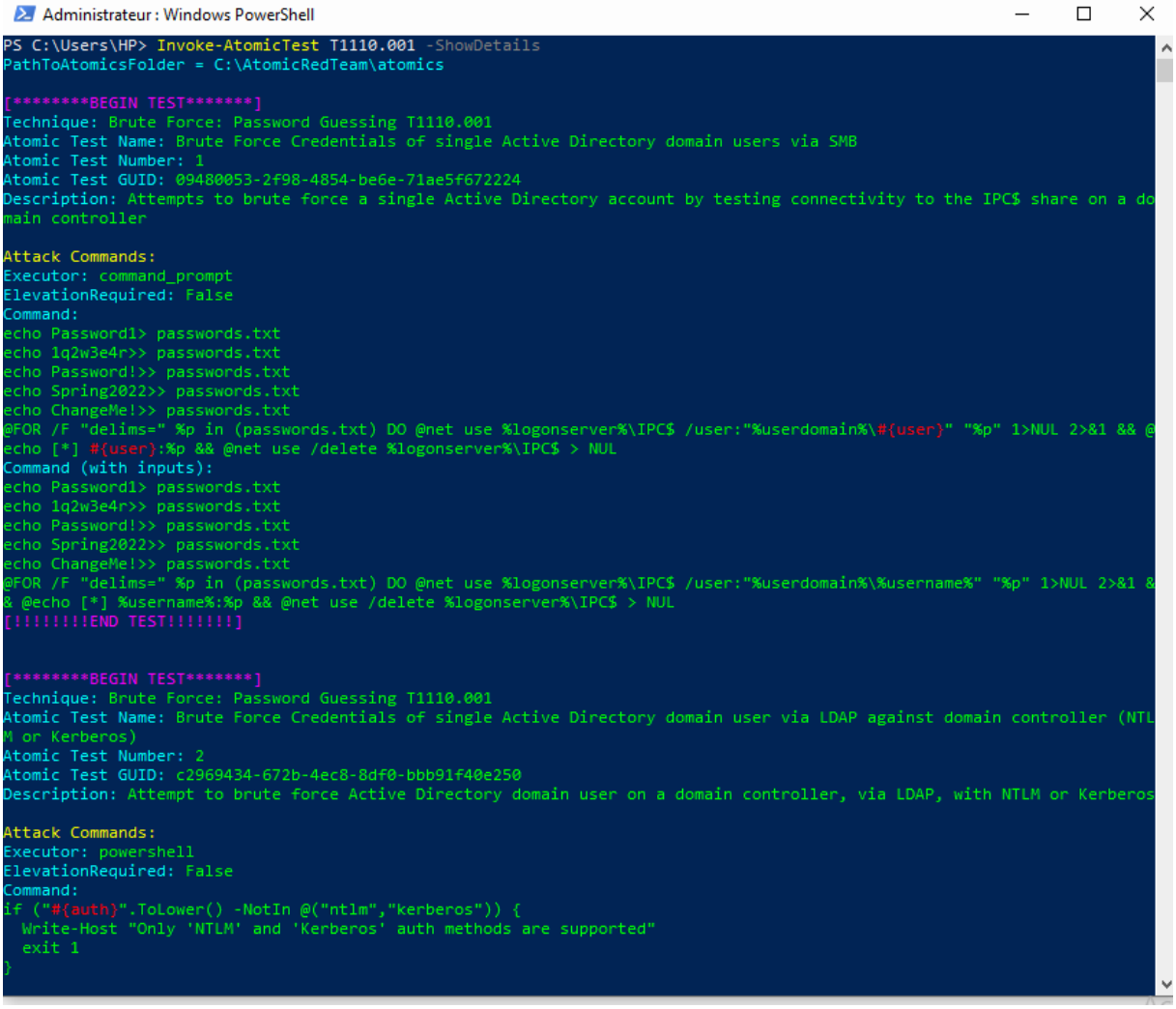
On renseigne le mail qui doit recevoir l'alerte.

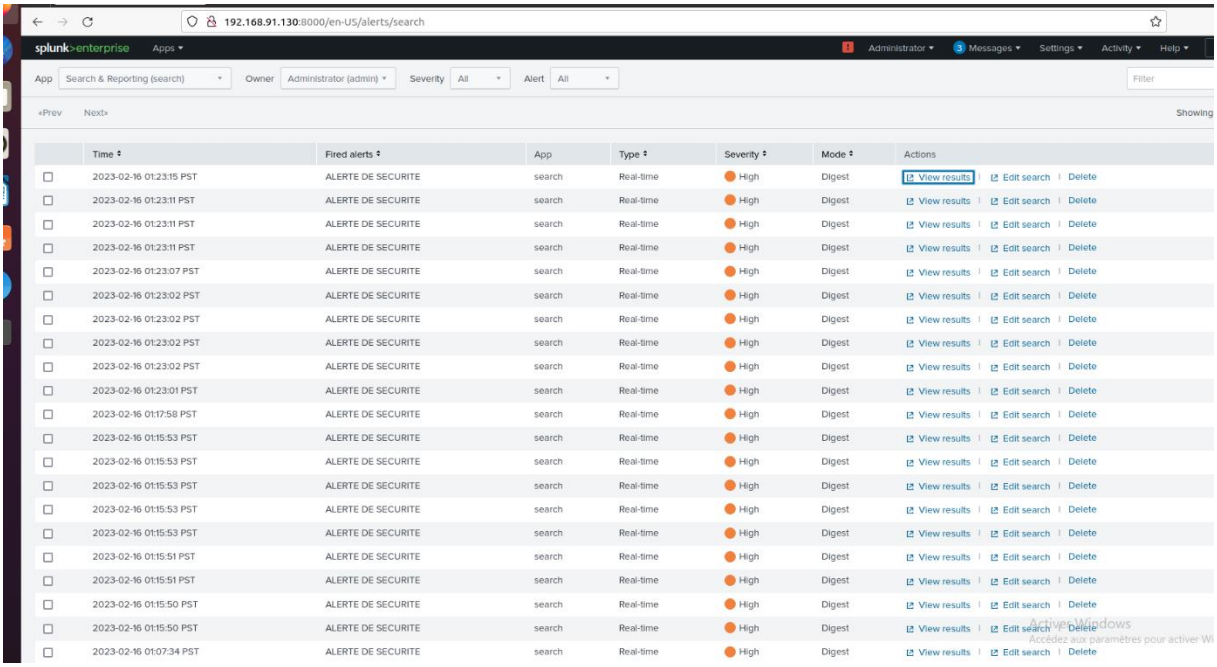


On sélectionne le niveau de sévérité de l'alerte.



Régénérons les mêmes événements avec notre outil. Comme sur l'image nous allons exécuter la technique **T1110.001** (brute force password) sur la machine. On peut le constater sur l'image ci-dessous.



```
Attack Commands:
Executor: powershell
ElevationRequired: False
Command:
cd $env:temp
.\kerbrute.exe bruteuser --dc #{domaincontroller} -d #{domain} $env:temp\bruteuser.txt TestUser1
Command (with inputs):
cd $env:temp
.\kerbrute.exe bruteuser --dc $ENV:userdnsdomain -d $ENV:userdomain $env:temp\bruteuser.txt TestUser1

Dependencies:
Description: kerbrute.exe must exist in $env:temp
Check Prereq Command:
if (test-path $env:temp\kerbrute.exe){exit 0} else {exit 1}
Get Prereq Command:
invoke-webrequest "https://github.com/ropnop/kerbrute/releases/download/v1.0.3/kerbrute_windows_386.exe" -outfile "$env
temp\kerbrute.exe"
Description: bruteuser.txt must exist in $env:temp
Check Prereq Command:
if (test-path $env:temp\bruteuser.txt){exit 0} else {exit 1}
Get Prereq Command:
invoke-webrequest "https://github.com/redcanaryco/atomic-red-team/blob/master/atomics/T1110.001/src/bruteuser.txt?raw=t
ue" -outfile "$env:temp\bruteuser.txt"
[!!!!!!!!END TEST!!!!!!!!]


PS C:\Users\HP>
```

Dans le menu du haut cliquons sur **Activity puis** sur **Trigger alert**. On voit bien que les alertes se sont déclenchées comme sur la figure